

MSc Project Notes

Threat Modelling for Human-Querying Agents

Student: Hassan Suliman

Supervisor: Umang Bhatt

Working title: [Current project title]

Date started: April 14, 2026

Last updated: April 26, 2026

Contents

1	Core Project Question	4
1.1	One-sentence version	4
1.2	Expanded version	4
1.3	Why this matters	5
1.4	Current best understanding	5
2	Draft Thesis Statement	6
3	System Model	6
3.1	What is the system I am studying?	6
3.2	Agent	7
3.3	Human API	7
3.4	Environment	7
3.5	Memory / World Model / Representation	8
3.6	Communication Channels	8
3.7	Action Space	8
3.8	Constraints	9
4	Adversary Model	9
4.1	Why an adversary model is needed	9
4.2	Threat actor, threat vehicle, threat target	9
4.3	Primary adversary	10
4.4	Attacker positions	10

4.5	Adversary goals	10
4.6	Adversary capabilities	11
4.7	Adversary limitations	11
4.8	Project-specific emphasis	11
5	Assets to Protect	12
5.1	Private Information	12
5.2	Human Attention / Time	12
5.3	Human Actions	13
5.4	Agent Memory / World Model	13
5.5	Social Graph / Network Structure	13
5.6	Institutional Trust / Workflow Integrity	14
6	Harm Model	14
6.1	What counts as harm in this project?	14
6.2	Information Harms	15
6.3	Action Harms	16
6.4	Resource Harms	16
6.5	Systemic Amplification	17
7	Security Properties (Informal Desiderata)	17
8	Why This Is a New Threat Surface	18
8.1	What is new	18
8.2	Why existing security framing is insufficient	18
8.3	Why existing privacy framing is insufficient	19
8.4	Why existing prompt-injection framing is insufficient	19
8.5	Why existing multi-agent framing is helpful but incomplete	19
9	Candidate Threat Taxonomy (Version 0)	20
9.1	Family A: Epistemic Exploitation	20
9.1.1	A1: Representation Extraction Attacks	20
9.1.2	A2: Adaptive Query Inference Attacks	21
9.1.3	A3: Cross-Human and Relational Inference Attacks	22

9.2	Family B: Behavioural Exploitation	22
9.2.1	B1: Human Orchestration Attacks	22
9.3	Family C: Resource Exploitation	23
9.3.1	C1: Attention and Oversight Load Attacks	23
10	Assumptions	24
11	Paper-to-Project Map	25
11.1	Human API paper	25
11.2	AI Agent Traps paper	25
11.3	Multi-Agent Security paper	25
11.4	Privacy paper	25
12	Per-Paper Extraction Notes	26
13	Open Questions	26
13.1	Conceptual Confusions	26
13.2	Scope Questions	26
13.3	Assumption Questions	26
13.4	Simulation Questions	26
13.5	Questions to Ask Umang / Kosta	26
14	Candidate Toy Instantiations	27
14.1	Toy Setup 1: Representation Recovery on the Human API (candidate)	27
14.2	Toy Setup 2: Human Endpoint as LLM (candidate)	27
14.3	Toy Setup 3: Attention / Burden Attack (candidate)	28
15	Early Paper Outline	28
15.1	Tentative Title	28
15.2	Abstract Sketch	28
15.3	Introduction Sketch	28
15.4	Section 1: System Model	28
15.5	Section 2: Threat Model	28
15.6	Section 3: Threat Taxonomy	28

15.7 Section 4: Example / Toy Instantiation	28
15.8 Section 5: Discussion / Assumptions / Limitations	28
16 Daily Log	29
17 Very Short Weekly Summary	29
18 One-Page Project Core	29
18.1 Problem	29
18.2 System	29
18.3 Attacker	29
18.4 Assets	29
18.5 Harm	29
18.6 Why Current Literature Is Insufficient	30
18.7 My Current Proposed Contribution	30

1. Core Project Question

1.1 One-sentence version

This project asks: *what new threats emerge when AI agents can both learn about humans by querying them as structured sensing actions and act through humans as part of their operational loop, while maintaining state about them across interactions?*^[7, 20, 18]

1.2 Expanded version

This project studies the security threat surface created by *human-querying agents*. In the Human API framing, humans are not treated as vague conversational partners but as explicit sensing actions with costs, constraints, and institutional control. An agent therefore decides not only whether to ask for more information, but also which sensing action to invoke, when to invoke it, and through whom. The Human API paper makes this explicit by contrasting ordinary follow-up questions with structured sensing actions that have names, costs, and expected value. ^[18]

My project asks what changes once this capability is viewed adversarially rather than helpfully. If an agent can query humans, maintain memory across interactions, and possibly build a representation or world model of a person and their network, then the attack surface is no longer just the model’s output channel. It also includes the agent’s stored representation of people, the queries it issues to humans, and the actions it can trigger through them.

In Umang’s framing, the first question is to define “what is the threat that emerges when agents

query humans,” and to sharpen this further by considering cases where “the attack surface is actually the world model itself.”

So the project is not primarily about improving decision quality or routing efficiency. It is about identifying and clearly characterizing a new class of security risks that arise when humans become callable parts of agentic systems and when the agent may store, update, and exploit representations of those humans over time.

1.3 Why this matters

The problem matters because the Human API framing already makes agents more powerful: it turns human input into explicit actions with names, costs, structured interfaces, and oversight. That is useful for decision-making, but it also means humans are no longer just passive users of a system. They become part of the system’s operational machinery. Once that happens, the relevant question is no longer only whether querying humans improves performance, but also what can go wrong when agents can systematically query, model, and act through people. [18]

This deserves its own threat model because existing security framings are incomplete. The multi-agent security paper argues that some threats emerge or become amplified specifically through interaction, and that these cannot be understood by analyzing isolated agents one by one. It explicitly contrasts this with traditional AI security and cybersecurity, which remain largely focused on individual systems, single-agent attack surfaces, and rigid access-control views rather than rich interaction dynamics. [20]

There is also a privacy reason this matters. The privacy paper argues that privacy in language is contextual, that secrets are hard to delimit, and that private information is often distributed across people, contexts, and records rather than stored neatly in one place. That makes human-querying agents especially concerning, because such agents may learn sensitive things indirectly by combining many small pieces of information over time, even when no single query appears obviously harmful. [4, 17]

1.4 Current best understanding

My current best understanding is that Umang wants this to begin as a *threat-modeling project first*, not as a defense paper and not as a heavily mathematical optimization project. The first milestone is to define the threat surface clearly: who the attacker is, what the agent can do, what the human API is, what kind of information or actions are at stake, and what kinds of harm count as security failures. In the transcript, he keeps returning to the same core question: what is the threat that emerges when agents can query humans?

More specifically, he seems to want the project framed around the idea that agents may maintain persistent state across interactions about a person, their network, or the information they can provide. In that case, the attack surface is not only the agent’s final responses, but also the stored representation itself. A useful way of making the problem more precise is to model this state as a world model or graph of a person and their network, but the core threat model should not depend on that representation being fully explicit.

My best reading of the intended contribution is therefore the following. The paper should define a new threat model for human-querying agents, centered on the fact that such agents can both *learn about people* and *use people* as part of their action loop. That includes risks such as indirect information recovery, exploitation of stored representations, overuse of human attention, and human orchestration through tools and communication channels. The project may later make one of these directions concrete through simulation, but the first deliverable is the conceptual framing itself.

A useful way to keep the framing precise throughout this document is to separate three roles that are often conflated in the existing agent security literature: the *threat actor* (the entity whose objectives the attack serves), the *threat vehicle* (the system through which those objectives are realised), and the *threat target* (the entity that suffers harm). The novelty of the project lies in characterising the vehicle: most existing work focuses on attacks where the agent is itself the target, whereas this project focuses on attacks in which the agent is the means and the queried human is the target. The threat actor may vary, but the vehicle and the target are what unify the attack surface. This distinction is developed formally in Section 4.

2. Draft Thesis Statement

Human-querying agents create a new security threat surface that existing AI security framings do not capture. Once an agent can issue structured queries to humans as part of its action loop and maintain state about those humans across interactions, two qualitatively new classes of attack become possible: the agent’s stored or implicit representation of a person can be *extracted* or *exploited* through the same interface that legitimately queries it, and the human can be *orchestrated* into actions in the world through the same interface that legitimately requests sensing. These attacks do not require model-weight access, prompt injection, or full agent autonomy; they exploit the ordinary operational logic of the human-querying system itself. This project defines that threat surface, characterises the conditions under which these attacks are possible, and outlines one concrete instantiation. In contrast to the prompt injection literature, the agent in this setting is not the victim of attack; it is the *vehicle* through which attacks on humans are conducted, regardless of whether the threat actor is a malicious principal, an external context-shaper, or a misaligned agent objective.

3. System Model

3.1 What is the system I am studying?

The system I am studying is a *human-querying agentic system* in which an AI agent can call humans as explicit parts of its workflow, maintain information across interactions, and use those interactions to gather information or produce downstream actions. This is broader than a standard prompt-response setting. The agent is not merely generating answers from a fixed input. It may query, store, update, and act through a combination of tools, memory, and human interaction.

For formal clarity, I use the Human API paper as the initial scaffold for this system. In that framing, humans are not treated as vague conversational partners but as explicit sensing actions

with costs, constraints, and institutional control. That gives a concrete starting point for reasoning about how an agent selects queries, acquires information, and operates under structured interaction constraints. [18]

However, my project is not limited to decision-making under uncertainty in the narrow sense. The broader concern is that once humans become callable components of an agentic workflow, the attack surface expands beyond the model’s output channel. It now includes the human-querying loop, the agent’s memory and stored representations, and the real-world effects of the actions the agent can trigger through people.

3.2 Agent

The agent in this project is best understood as a tool-using system with the ability to decide how to gather information and how to act on it. It may begin with some initial context, identify informational gaps, query one or more humans, update its internal state, and then produce downstream actions or recommendations. In the Human API framing, this appears as a query policy over structured sensing actions together with a terminal action policy. [18] The general capability of an LLM-based agent to call structured external interfaces is well established in the tool-use literature, where models can learn to invoke APIs from a small number of demonstrations. [19]

For my purposes, the important point is not only that the agent can ask questions, but that it can decide *which* human to query, *how* to query them, and *when* to do so as part of an operational workflow. This makes the agent interesting from a security perspective because the querying process itself may become part of the threat surface.

3.3 Human API

The Human API is the central object in the system. In the Human API paper, querying a human is formalized as an explicit action with a name, semantics, cost, and expected informational value, rather than as an informal follow-up question in open conversation. The significance of this distinction is that explicit actions can be reasoned about, constrained, logged, and governed in a way that ordinary conversation cannot. [18]

This is exactly what makes the setup relevant for threat modelling. Once a human becomes an explicit callable part of the action space, the question is no longer only whether the query improves the agent’s performance. It also becomes possible to ask whether the query extracts sensitive information, burdens the human, exploits the human’s role in the system, or uses the human to achieve some other downstream objective.

3.4 Environment

The environment contains both non-human and human sources of information. Some parts of the environment are already instrumented and accessible through ordinary APIs, tools, records, or workflows. Other parts are not directly available to the agent and must be accessed through human-mediated interaction. The Human API paper emphasizes exactly this distinction between

machine-readable interfaces and information that exists only in people, tacit knowledge, physical observations, and local judgment. [18]

For this project, the environment should be understood broadly. It includes the digital systems the agent uses, the humans it can query, the institutions or workflows that regulate those queries, and any surrounding social or organizational structure that shapes what information can be accessed and how. This broader view matters because the project is not only about information access, but also about how querying humans changes the security properties of the overall system.

3.5 Memory / World Model / Representation

A central working assumption of this project is that the agent maintains some persistent state across interactions about a person, a network of people, or information acquired through prior interactions. I do not need to assume at this stage that all current agents literally store a clean explicit graph of a person. What matters is that the system is not memoryless, and that past human responses can influence future querying, representation, and action. The Human API framework already assumes accumulated observations and belief updates across sequential interaction. [18]

My project extends this by taking seriously the possibility that stored representations themselves may become part of the attack surface. In that case, the threat is not limited to harmful outputs. It may also involve recovering information from memory, exploiting the structure of what the agent knows, or using that representation to decide whom to query next and what to ask. This is one of the main reasons the project should be framed more broadly than a simple decision problem.

3.6 Communication Channels

The system includes one or more channels through which the agent can interact with humans. In the Human API paper, these appear as structured sensing actions in a predefined registry, and the experimental setup models humans as simulated endpoints that return observations when invoked. [18]

For this project, the exact communication channel does not need to be fixed at the outset. What matters is that the agent can in principle contact or query humans through some operational mechanism, and that these interactions are part of the system’s normal workflow rather than exceptional events. This leaves open multiple later instantiations, such as structured query actions, message-based interactions, or other tool-mediated forms of human contact.

3.7 Action Space

The action space of the system includes both non-human and human-mediated actions. In the Human API framework, this is captured by a set of allowed sensing actions, each with associated costs and observation structure. The framework also distinguishes between the agent’s ability to propose a sensing action and the system’s authority to execute it, which keeps the action space structured rather than unbounded. [18]

For my project, the important point is that the agent operates over a mixed action space. It can gather information, update internal beliefs or representations, and eventually take downstream actions, but one especially important subset of this action space involves humans. This is the subset I want to analyze from a security perspective.

3.8 Constraints

The system is not assumed to be unconstrained. The Human API paper explicitly includes costs, structured action sets, and human or institutional control over which sensing actions are actually executed. Humans may accept, modify, or reject proposed actions, meaning that the realized information flow is co-produced by the agent’s policy and the human or institutional response. [18]

This matters for my project because the threat model should not assume an all-powerful agent. The interesting security question arises precisely in the space between capability and control: the agent can propose queries, maintain memory, and act through a structured workflow, but it does so under incomplete information, limited authority, and human oversight. This makes the resulting threat surface more realistic and more subtle than a simple formulation in which the agent can do anything without friction.

4. Adversary Model

4.1 Why an adversary model is needed

A clear adversary model is necessary because the system studied in this project is not a closed prediction system. It is a human-querying agentic system in which an AI agent can acquire information through explicit human-facing actions, store information across interactions, and use those interactions as part of a broader workflow. In the Human API framing, these actions are structured, costed, and subject to institutional control, which means that the relevant threat is not simply “the model makes a mistake.” The relevant threat is that an adversary may exploit the agent’s normal querying and information-gathering interfaces in order to induce harmful behavior, extract sensitive information, or exploit humans as parts of the system. [18, 7, 20]

4.2 Threat actor, threat vehicle, threat target

It is useful to separate three roles that are conflated in much of the existing agent security literature. The *threat actor* is the entity whose objectives the attack serves. The *threat vehicle* is the system through which those objectives are realised. The *threat target* is the entity that suffers harm. In the prompt injection literature [9, 7], the actor is typically an external content provider, the vehicle is the agent’s input channel, and the target is the agent or its principal.

In this project, the configuration is different. The threat target is the queried human. The threat vehicle is the agent’s human-querying interface together with its stored representation of the human. The threat actor may be (1) a malicious or merely misaligned principal who tasks the agent in ways that encourage exploitative querying, (2) an external party who shapes the agent’s context

or task in a way that biases its querying policy without directly compromising the model, or (3) the agent itself if its objective is misaligned with respect to the queried human. The threat surface defined in this project is intended to be invariant across these three actor positions; what unifies them is that they all act through the same vehicle against the same target.

This distinction matters because it foregrounds an asymmetry that is largely absent from the existing literature. Prompt injection studies attacks where the agent is the victim. This project studies attacks where the agent is the means.

4.3 Primary adversary

Within this structure, I treat the primary adversary as any actor who has effective read or write influence over the agent’s context, task inputs, surrounding environment, or interaction channels, without requiring full control over the model internals. This adversary need not have privileged access to model weights or arbitrary access to private memory stores. What matters is that the adversary can shape what the agent sees, what it is asked to do, or how its human-querying policy is triggered through realistic interfaces exposed by the system itself.

This framing is deliberately conservative. It focuses on attack surfaces that arise through ordinary system operation rather than through unrealistic assumptions of total compromise. This is also consistent with the broader literature on multi-agent security and agent traps, both of which emphasize that meaningful threats can emerge through interaction and environmental manipulation rather than only through direct control of a model. [7, 20]

4.4 Attacker positions

At this stage, it is useful to allow more than one possible attacker position. One possibility is a malicious requester or principal who gives the agent tasks that encourage harmful querying behavior. A second possibility is an adversarial external party who can shape the context surrounding the agent’s operation, for example by influencing the information environment through which the agent forms beliefs or chooses queries. A third possibility is another agent or system participant in a shared environment whose interactions with the focal agent create opportunities for exploitation, inference, or manipulation.

I do not yet need to choose a single attacker position as the only one of interest. However, all of these possibilities share a common feature: they exploit the fact that the agent can interact with humans as explicit parts of its action loop, and that the system may accumulate and act on information acquired through those interactions. [7, 20]

4.5 Adversary goals

The adversary’s goals in this project are best understood functionally rather than morally. A successful adversary is one that can cause the system to produce a security-relevant failure. At this level of abstraction, the main goals include extracting sensitive information, inferring hidden attributes or structure about a person or network, inducing or exploiting unnecessary human bur-

den, and causing the agent to use humans or tools in ways that violate the intended boundaries of the system.

These goals are intentionally broad enough to cover multiple concrete attack pathways later, but narrow enough to stay within the scope of this project. The point is not to model every possible harm in society. The point is to identify the characteristic ways in which a human-querying agent can be made to learn about people or use people in ways that create a new security threat surface.

4.6 Adversary capabilities

I assume that the adversary can interact with the system through the interfaces that are ordinarily available in deployment. Depending on the precise instantiation, this may include providing tasks, influencing contextual information, interacting repeatedly with the agent over time, or exploiting the fact that the agent can choose among structured human-facing actions. I also allow for the possibility that the adversary can benefit from the agent’s memory or stored representation indirectly, for example by eliciting outputs or behaviors that reveal what the agent has learned about a person.

Crucially, the adversary is assumed to exploit the system’s normal operational logic rather than bypass it entirely. This is important because the Human API framework itself emphasizes that the system has explicit sensing actions, structured action sets, and control over information flow. A useful adversary model for this project should therefore focus on how those very mechanisms can be exploited, not only on catastrophic full compromise. [18]

4.7 Adversary limitations

I do not assume that the adversary has direct access to model weights, unrestricted read access to internal memory, or arbitrary authority to force execution of any desired action. I also do not assume that humans are perfectly compliant. In the Human API framework, proposed sensing actions may be accepted, modified, or rejected by a human or institutional policy, and the action space itself is structured rather than fully open-ended. [18]

These limitations are essential for keeping the threat model realistic. If the adversary were assumed to have unrestricted internal access or absolute control over all human participants, then the most interesting part of the problem would disappear. The project would collapse into a trivial statement that fully compromised systems are dangerous. The more interesting scientific question is what an adversary can achieve without such unrealistic powers, simply by exploiting the querying, memory, and interaction structure of the system.

4.8 Project-specific emphasis

Within this general adversary model, the specific emphasis of my project is on the possibility that the agent may maintain an explicit or implicit representation of a person, their network, or the information they can provide. In that case, the adversary is not only attacking a sequence of

outputs. The adversary may also be attacking the representation itself: trying to recover it, update it in a harmful direction, or exploit it to determine whom the agent queries and what it asks.

This emphasis makes the project more precise while remaining within scope. Rather than trying to solve all possible attacks on all agentic systems, the project focuses on a narrower and more scientifically tractable question: **what adversary becomes possible once an agent can query humans as explicit parts of its workflow and maintain representations of them over time?**

5. Assets to Protect

The purpose of this section is to identify what is actually at stake in a human-querying agentic system. In a conventional security analysis, the natural focus might be on model weights, databases, or standard secrets such as credentials. In this project, however, the relevant assets are broader. Because the system explicitly treats humans as callable parts of an agentic workflow, the assets to protect include not only private information, but also scarce human attention, the integrity of human action, the agent’s stored representations, the structure of relationships between people, and the reliability of institutional workflows. These assets are what make the threat model meaningful: if an adversary can compromise them, then the agent has become a security-relevant risk rather than merely a fallible prediction system.

5.1 Private Information

Private information is the most immediate asset, but it should be understood broadly rather than as only obvious personally identifying information. The privacy literature emphasizes that linguistic privacy is contextual, that the boundaries of a secret are often difficult to define, and that sensitive information is frequently distributed across multiple people, records, and interactions rather than residing neatly in one location. This matters for my project because a human-querying agent may learn sensitive things indirectly, through accumulation, inference, and selective querying, even when no individual query appears clearly harmful in isolation. [4, 17]

In this project, private information therefore includes not only explicit facts about a person, but also latent attributes, preferences, vulnerabilities, health-related details, institutional roles, and information that becomes sensitive because of the context in which it is combined or disclosed. The relevant privacy concern is not only direct leakage. It is also the possibility that the system infers, reconstructs, or operationalizes private information that humans did not intend to expose through ordinary use of the system.

5.2 Human Attention / Time

Human attention and time should be treated as first-class assets rather than as free resources. The Human API paper makes this especially clear by arguing that sensing actions are not free: they incur costs in money, time, risk, and human attention, and they should therefore be modeled explicitly rather than hidden inside ordinary conversation. [18]

This matters for the threat model because an adversary need not extract a secret in order to create harm. It may be enough to induce the agent to over-query, to repeatedly burden the same individuals, or to consume scarce human effort in ways that are wasteful, manipulative, or strategically disruptive. In this sense, human time is an asset because it is both limited and operationally important. A system that treats human attention as effectively free creates an attack surface even if no direct information theft occurs.

5.3 Human Actions

Human actions are also assets to protect. Once a system can query humans as explicit parts of its workflow, it may not only gather information from them but may also shape what they do. In the Human API framing, the relevant question is no longer merely what the agent knows, but also what the agent causes humans to do by requesting tests, asking for observations, or directing effort through structured workflows. [18]

For this project, the core concern is not immersive persuasion or dramatic coercion, but the more general possibility that a human-querying agent induces actions that violate the intended purpose or boundaries of the system. These actions may include unnecessary work, disclosure of sensitive observations, operational actions taken under false premises, or actions that shift risk or responsibility onto humans without appropriate control. The asset here is therefore the integrity of human action within the system: humans should not become unexamined actuators for adversarial or misaligned objectives.

5.4 Agent Memory / World Model

The agent’s memory, world model, or stored representation is a central asset in this project. The Human API framework already assumes that the system updates beliefs over time as it accumulates observations, and the Agent Traps paper highlights memory and learning as explicit attack targets through cognitive state traps, latent memory poisoning, and memory extraction. [18, 7]

This matters because the representation itself may be valuable even when no final output reveals it directly. If the agent stores a structured picture of a person, a network, or a history of past interactions, then that stored representation can be exploited, queried indirectly, or manipulated in ways that change future behavior. In my project, this is one of the key reasons the threat model extends beyond ordinary prompt injection: the stored model of a person may itself become part of the attack surface, not just the immediate response generated from a prompt.

5.5 Social Graph / Network Structure

The social graph or network structure around a person is another important asset. The privacy paper argues that private information is often shared across multiple individuals and records, and not cleanly attributable to a single owner. Likewise, the multi-agent security perspective emphasizes that threats can arise through interactions among agents, humans, and institutions, and that shared environments can amplify harms such as privacy breaches and misinformation dynamics. [4, 20]

For this project, the important idea is that relationships themselves may be sensitive. Knowing who can be queried, who trusts whom, who has access to what, or who is connected to which institutional process may enable inference and exploitation even when each individual fact looks innocuous on its own. The asset is therefore not only the content of what people know, but also the structure of how people, roles, and channels are connected.

5.6 Institutional Trust / Workflow Integrity

Finally, institutional trust and workflow integrity are assets to protect. The Human API paper explicitly models human and institutional control over what sensing actions are actually executed, while the multi-agent security paper argues that sociotechnical interfaces involving humans, organizations, and social institutions create systemic risks that require both technical and governance-oriented protection. [18, 20, 11]

This matters because the agent is embedded in a workflow rather than operating in isolation. If the system over-queries, routes work inappropriately, exploits loopholes in institutional control, or degrades confidence in the reliability of the overall process, then the harm is not reducible to one bad output. It is a degradation of the trust, accountability, and role structure that make the system usable in the first place. The Agent Traps paper also points in this direction when it stresses accountability gaps and the need for ecosystem-level safeguards once agents operate in broader digital environments. [7]

Taken together, these assets show that the threat model for human-querying agents is broader than a standard confidentiality analysis. What is at stake is not only whether an agent leaks a secret. It is whether the system can appropriate human attention, misuse human action, exploit stored representations, infer relational structure, and erode institutional safeguards through the ordinary operation of a human-querying workflow.

6. Harm Model

The purpose of this section is to define what counts as a security-relevant failure in a human-querying agentic system. In this project, harm is not restricted to catastrophic model failure or to direct disclosure of a secret. Instead, harm occurs whenever the agent’s ability to query humans, maintain information across interactions, or act through structured workflows leads to outcomes that violate the intended informational, operational, or institutional boundaries of the system. This broader framing is necessary because the Human API setup already treats human input as explicit sensing actions with costs, constraints, and control over information flow, while the surrounding literature shows that harms in such systems may arise through memory, action, oversight, and interaction effects rather than through direct compromise alone. [18, 7, 20]

6.1 What counts as harm in this project?

In this project, harm should be understood as any outcome in which the system’s normal operation is exploited in a way that compromises a protected asset or violates a legitimate control boundary.

This includes, but is not limited to, privacy violations, indirect inference of sensitive information, misuse of scarce human attention, induced human action under inappropriate conditions, corruption or exploitation of stored representations, and the amplification of these effects through larger sociotechnical or multi-agent processes. The point is not to claim that every bad outcome is equally severe. Rather, the aim is to define a family of security-relevant failures that are characteristic of human-querying systems and that would not arise, or would arise in a weaker form, in systems that do not treat humans as callable components of an agentic workflow. [18, 20]

To keep the harm model parsimonious and aligned with the taxonomy that follows, I group these into four families: information harms, action harms, resource harms, and systemic amplification.

6.2 Information Harms

I adopt a contextual integrity framing of information harm [17, 4]: harm occurs when information about a person flows in ways that violate the norms of the context in which it was originally disclosed. This framing is well-suited to human-querying agents because the harm is not that information exists in some store, but that the agent’s ability to elicit, recombine, and operationalise information across queries can produce flows that no individual interaction would have authorised. Recent work has applied contextual integrity directly to LLM-based agents and shown that even privacy-conscious users routinely produce disclosures that violate it under benign conversational framing. [15, 16]

Within this framing, two related but distinct harms arise. The first is *privacy harm*: the system reveals, reconstructs, uses, or operationalizes information about a person outside the informational boundaries that would be appropriate for the context in which that information was provided. This is not limited to direct leakage of a phone number, diagnosis, or identifier; it also includes context violations in which information is surfaced, recombined, or repurposed in ways the relevant people did not authorize or reasonably expect. [4]

The second is *inference harm*: the system derives sensitive attributes, hidden structure, or consequential conclusions from partial, distributed, or apparently innocuous information. This is well-precedented empirically: prior work has shown that sensitive attributes such as personality, sexual orientation, and political views can be predicted with substantial accuracy from innocuous behavioural signals such as Facebook likes. [12] A human-querying agent that can issue many small, individually innocuous queries against humans is a natural extension of this same inference capability into an interactive setting. The key point is that a system can become dangerous even when it never explicitly asks for or reveals the final sensitive fact. If the agent can reliably infer it and then act on it, that is already a security-relevant harm.

For this project, information harm includes both explicit disclosure and inappropriate downstream use. If a human-querying agent asks multiple seemingly benign questions and then uses the resulting information to build a more sensitive picture of a person than any single participant intended to provide, that should count as information harm. Likewise, if the agent’s stored representation of a person enables future disclosure, targeting, or exploitation, the violation may lie not only in what is output immediately, but in the fact that the system has come to possess and use that information in the first place.

6.3 Action Harms

Action harms occur when the agent’s interactions with humans cause those humans to do something they otherwise would not have done, or to do something under conditions that violate the intended purpose or boundaries of the workflow. Two related variants are worth distinguishing.

The first is *manipulation*: the agent’s interactions are used to shape human beliefs, judgments, or behavior in a way that serves adversarial or system-inappropriate objectives. This is broader than overt coercion. The relevant concern is that the agent may not only gather information from humans, but may also steer them by how it frames requests, what it asks, what it withholds, or how it sequences interactions. The Agent Traps paper is useful here because it emphasizes semantic manipulation and human-in-the-loop attack surfaces, where the human participant or overseer becomes part of the vulnerability rather than merely an external safeguard. [7] Recent work on the persuasion capabilities of frontier models is also relevant, both as a baseline capability claim and as a forward-looking concern. [1]

The second is *induced action*: the agent gets a human to perform a concrete action in the world, rather than only updating their beliefs. The Human API framework already makes clear that querying humans is not only about extracting facts; it may involve requesting examinations, tests, observations, or other concrete steps in the world. [18] For this project, induced-action harm includes cases where the agent triggers unnecessary tests, causes operational actions to be taken under misleading premises, shifts risk or liability onto human participants, or turns humans into effective actuators for goals they do not adequately understand.

The unifying concern is whether the agent can use humans instrumentally in ways that bypass the intended safeguards of the system. This is what makes the transition from “human as information source” to “human as part of the action loop” security-relevant.

6.4 Resource Harms

Resource harms occur when the system consumes scarce human time, effort, or cognitive capacity in ways that are unnecessary, unfairly distributed, or strategically exploitable. This is one of the clearest places where the Human API paper matters, because it insists that sensing actions are not free: they incur costs in money, time, risk, and attention, and those costs should be modeled explicitly rather than hidden inside ordinary conversation. [18].

In this project, resource harm includes repeated or excessive querying, concentrated burden on particularly knowledgeable humans, induced interruptions, and the use of querying as a denial-of-service analogue against people rather than machines. A system can therefore be harmful even if every individual query is superficially legitimate. If the cumulative effect is to waste scarce human effort, overload institutional processes, or degrade the quality of human oversight, that should count as a meaningful harm.

6.5 Systemic Amplification

Systemic amplification occurs when many individually small or locally plausible interactions accumulate into larger failures at the level of institutions, networks, or populations. The multi-agent security paper is especially helpful here, because it argues that threats can emerge or become amplified through interaction and that these may include cascading privacy breaches, covert coordination, distributed manipulation, oversight failures, and broader societal disruption. [20, 11] The Agent Traps paper also supports this broader view by distinguishing systemic traps from single-agent attacks and by emphasizing that interaction can seed macro-level failures through correlated behavior, congestion, cascades, or manipulation of shared environments. [7]

In this project, systemic amplification includes cases where querying practices erode institutional trust, where private information spreads through networks in ways no individual interaction would reveal, where many mild burdens aggregate into serious strain on human workers, or where the agent’s interaction with one person changes the risk profile for many others. This matters because a human-querying threat model should not stop at one agent and one target. Once querying, memory, and action are embedded in real workflows, harms can propagate through social, organizational, and technical structures.

Taken together, these four harm families show that the harm model for human-querying agents must be broader than simple confidentiality loss. What matters is not only whether the system leaks data, but whether it exploits people as sensors, burdens them as resources, induces them as actuators, infers sensitive structure from distributed signals, and amplifies those effects through stored representations and larger interaction networks. [18, 4, 7, 20]

7. Security Properties (Informal Desiderata)

The threat model implies, informally, three properties that a well-behaved human-querying agent should approximate. I state these as desiderata rather than as formal guarantees: they are intended to give the threat families that follow a clear referent for what “failure” means, not to anticipate proofs or quantitative bounds. Formalisation is left to future work and may require commitments about distributions, posteriors, and adversary classes that are deliberately not made here.

Information containment. For information that is outside the legitimate scope of a task, the agent’s accumulated knowledge about that information after the task should not be substantially greater than its prior, regardless of how its querying policy is shaped during the task. Failures of information containment correspond to information harms (Family A in the taxonomy below).

Authorised actuation. For human-mediated actions whose cost, risk, or downstream consequence exceeds the level routinely authorised within the workflow, the agent should not be able to induce those actions without explicit authorisation at a granularity matching their seriousness. Failures of authorised actuation correspond to action harms (Family B).

Bounded resource consumption. For any individual human and any reasonable time window, the cumulative attention or effort demanded by the agent should be bounded by some level appropriate to that person’s role and capacity within the workflow. Failures correspond to resource harms (Family C).

These properties are deliberately stated qualitatively. A threat model that demands zero information leakage, zero unauthorised action, or zero resource consumption is unrealistic; the security question is whether realistic deployments can approximate these properties against realistic adversaries. The point of stating them is to make the rest of the document’s notion of “security failure” concrete enough to be argued with.

8. Why This Is a New Threat Surface

8.1 What is new

The threat surface defined in this project has two distinguishing features. First, the agent’s interface to humans is treated as both an information-gathering channel and a behaviour-shaping channel, which means the same querying mechanism that legitimately reduces uncertainty can also be exploited to extract sensitive information and to induce real-world actions. Second, the agent maintains state about the humans it queries, which means the attack surface is not bounded by any single interaction: it includes the agent’s accumulated and potentially structured representation of a person, even when that representation is implicit. No prior framing combines these two features as a single security object. The remainder of this section explains why each existing framing falls short of doing so.

8.2 Why existing security framing is insufficient

Existing security framing is insufficient because it usually treats the protected system as an individual model, service, or database, and focuses on familiar concerns such as unauthorized access, direct compromise, or model-centric failures. By contrast, the system in this project is a human-querying agentic system in which the agent can explicitly call humans as parts of its workflow, accumulate information across interactions, and use those interactions to guide future querying and action. The Human API paper is useful here because it makes clear that this is not just ordinary conversation: once humans become explicit sensing actions with costs, constraints, and institutional control, the relevant object is a larger sociotechnical system rather than a stand-alone model. At the same time, the multi-agent security literature argues that traditional cybersecurity and single-agent AI security frameworks are poorly suited to threats that emerge or amplify through interaction. My project sits precisely at that boundary: it is about a new attack surface created by the interaction between agents, humans, memory, and workflow, rather than about compromise of a single isolated component. [18, 20]

8.3 Why existing privacy framing is insufficient

Existing privacy framing is insufficient because it often centers on disclosure, memorization, or protection of already-existing data records, whereas my project concerns agents that can actively query humans, combine distributed observations, and build increasingly consequential representations over time. The privacy paper is especially important here because it argues that privacy in language is contextual, that the boundaries of a secret are often difficult to define, and that private information is frequently distributed across multiple people and records rather than neatly contained in one place. That helps explain why a purely data-protection view is too narrow for this project. The threat is not only that a system may leak something already stored. It is also that the system may selectively elicit, recombine, and operationalize information about a person through repeated querying and inference. In other words, once an agent can learn about people through interaction, privacy is no longer only a question of what data it has, but also of what it can come to know and use through the querying process itself.[4, 17, 15]

8.4 Why existing prompt-injection framing is insufficient

Existing prompt-injection framing is insufficient because it mainly studies how malicious instructions enter an agent’s context through content, tools, retrieval, or the surrounding environment, thereby causing the agent to misbehave. [9] That framing is clearly relevant, and the Agent Traps paper is valuable precisely because it expands the attack surface beyond prompt strings to include memory, action, systemic dynamics, and human-in-the-loop vulnerabilities. [7] However, my project is not only about the agent being manipulated by external content. It is also about the agent itself becoming the vehicle of security risk by querying humans strategically, modeling them over time, and using them as information sources or operational components. In other words, prompt injection explains how agents can be deceived by hostile inputs, but it does not fully capture the distinct problem of agents that can actively and adaptively extract, infer, and exploit information from humans even when no malicious prompt has been injected into the system. The new threat surface therefore lies not just in hostile content, but in the structured human-querying capability itself.

8.5 Why existing multi-agent framing is helpful but incomplete

Existing multi-agent framing is helpful because it already recognizes that important threats emerge through interaction, private information states, shared environments, and sociotechnical interfaces rather than through isolated agents alone. The multi-agent security paper is especially useful here because it explicitly argues that new threats arise when agents interact with each other, with humans, and with institutions, and that these cannot be understood through single-agent analysis. [20, 11] This is very close to the spirit of my project. However, it remains incomplete for my purposes because my project is not primarily about agent-agent collusion, swarm behavior, or open decentralized ecosystems in general. It is about a more specific and underdefined threat surface: agents that can query humans as explicit parts of their action loop, maintain representations of those humans, and exploit the resulting informational and operational asymmetries. In that sense, the multi-agent perspective provides an important outer frame, but the core novelty of my project

lies in making the human-querying interface itself the central security object. This is also consistent with Umang’s framing, as threat emerges when agents can query humans, and the attack surface may become especially sharp once the agent’s representation of a person is made explicit.

9. Candidate Threat Taxonomy (Version 0)

The threats characteristic of human-querying agents fall into three families distinguished by what the attacker exploits about the agent: what the agent *knows* about the human (epistemic exploitation), what the agent can cause the human to *do* (behavioural exploitation), and what the agent can *consume* from the human (resource exploitation). Within each family, several distinct attack categories emerge from the specific mechanism employed. The taxonomy is designed to assume only that an agent can query at least one human through some operational interface, update its internal state across interactions, and use those interactions to guide future information gathering or action. [18, 7, 20, 4]

9.1 Family A: Epistemic Exploitation

These threats exploit what the agent knows or can come to know about a human. The shared mechanism is that information acquired through structured querying, and stored across interactions, can be recovered, manipulated, or extended through the same querying interface. We identify three subtypes.

9.1.1 A1: Representation Extraction Attacks

Short definition: Threats in which an adversary exploits, recovers, manipulates, or benefits from the agent’s stored or inferred representation of a person, group, or network.

Target: The agent’s memory, belief state, world model, profile of a person, or other persistent internal representation.

Mechanism: The threat works by taking advantage of the fact that the agent is not memoryless. As it queries humans and accumulates observations, it may build a structured representation of a person or their environment. An adversary may then exploit that representation directly or indirectly: by eliciting outputs that reveal it, by steering how it is updated, or by using it to predict what the agent knows and how it will query in the future. This category is closely related to the broader literature on memory attacks and cognitive-state attacks in agents. [18, 7]

Example: A strong recent example is ADAM, which presents an adaptive querying attack that extracts private information from agent memory by estimating the memory data distribution and using entropy-guided querying. The paper shows that sensitive information stored in memory can be exposed through benign-looking queries rather than through direct privileged access. A complementary example is AgentLeak, which shows that in multi-agent systems sensitive data can leak through inter-agent messages, shared memory, and tool arguments, and that output-only audits miss a large fraction of violations. [14, 6]

Why this is specifically about human-querying agents: This threat becomes sharper when the agent can acquire information by querying humans over time. In that setting, the agent’s representation is not just learned from static data or pretraining; it is actively constructed through interaction. That makes the stored representation itself part of the attack surface.

What harm it causes: Information harm (privacy and inference variants), downstream manipulation, misuse of stored personal information, and future vulnerability amplification.

What assumptions it needs: The system maintains some persistent state across interactions and querying can influence what the system comes to know. This does *not* require a perfectly explicit social graph or a full symbolic world model.

9.1.2 A2: Adaptive Query Inference Attacks

Short definition: Threats in which the agent learns sensitive or consequential information by strategically selecting and sequencing human queries.

Target: The information channel between the agent and the human, especially the agent’s query policy and the human’s responses.

Mechanism: The threat works by asking small, targeted, or apparently innocuous questions whose answers can be combined to infer more sensitive facts than any one response directly discloses. Because the agent can adapt later queries based on earlier answers, the resulting inference process may be much more powerful than a single direct request. This category is closely related to the Human API framing, where queries are explicit sensing actions chosen to reduce uncertainty, and to the privacy literature, which emphasizes that sensitive information is often distributed and inferable rather than directly stated. [18, 4, 12]

Example: A useful direct precedent is the contextual privacy work of Ngong et al., which shows that even privacy-conscious users inadvertently reveal sensitive information through indirect disclosures in conversations with LLM-based agents. A second example is the CMPL auditing framework, which studies iterative probing in multi-turn interactions and shows that adaptive adversaries can cautiously probe, observe partial disclosures, refine hypotheses, and circle back with more pointed questions to induce contextual privacy leakage. [16, 5, 15]

Why this is specifically about human-querying agents: This threat depends on the fact that the agent can actively *choose* what to ask, from whom, and in what order. That makes the querying process itself part of the inference mechanism, rather than a passive receipt of already-available data.

What harm it causes: Information harm (especially the inference variant), profiling, increased susceptibility to future manipulation, and unauthorized construction of sensitive beliefs about a person or group.

What assumptions it needs: The agent can issue at least one human query, queries can depend on previous observations, and the answers contain some information relevant to latent sensitive traits. This does *not* require access to private databases or perfectly truthful human responses.

9.1.3 A3: Cross-Human and Relational Inference Attacks

Short definition: Threats in which information about one person is inferred, exposed, or acted upon through querying other people or through the relational structure connecting them.

Target: Social graph structure, interpersonal relationships, role structure, and cross-person information flows.

Mechanism: The threat works by exploiting the fact that one person’s sensitive information may be partially distributed across others, and that relationships themselves often reveal consequential facts. By querying one human about another, or by combining partial responses across a network, the agent can infer hidden structure, sensitive relationships, or information that no single participant intended to reveal. This category is supported by the privacy literature’s emphasis on multi-person secrets and by interaction-based security work that highlights network effects and propagation. [4, 20]

Example: A useful conceptual example comes from the privacy literature itself: Brown et al. emphasize that one person’s private information often appears in other people’s records or conversations, such as cases where one employee shares another person’s sensitive information or where a secret persists across multiple participants’ messages. A broader empirical precedent comes from the shadow-profile literature, which shows that personal information about individuals can be inferred from the data contributed by others in the network, even when the focal individual did not directly provide that information themselves. [4, 8]

Why this is specifically about human-querying agents: This threat is specific because the agent can use humans as distributed sensors over a relational environment. The key capability is not only querying one person, but using one person’s answer to decide which other person to query next and what hidden structure can be recovered from the resulting network of observations.

What harm it causes: Information harm (privacy and inference variants), relational profiling, cross-person exposure, and network-level amplification of sensitive information.

What assumptions it needs: Information about one person may be held by others, and the agent can combine answers across more than one interaction. This does *not* require a complete explicit social graph or a large-scale decentralized agent ecosystem.

9.2 Family B: Behavioural Exploitation

These threats exploit what the agent can cause humans to do. The shared mechanism is that the human-querying interface is not purely epistemic: queries can trigger downstream actions in the world, and these actions can be made to serve attacker objectives.

9.2.1 B1: Human Orchestration Attacks

Short definition: Threats in which the agent uses humans not only as sensors but as operational components that perform actions serving adversarial or system-inappropriate objectives.

Target: Human behavior in the loop, especially actions taken in response to agent requests,

instructions, or workflows.

Mechanism: The threat works by converting a human from an information source into an actuator. The agent may induce someone to perform a test, send a message, check a system, reveal an observation, or otherwise take an action that the human would not have taken under a clearer or better-governed process. This connects closely to action-oriented threat categories in the broader agent security literature, including behavioural control and human-in-the-loop vulnerabilities, and to forward-looking concerns about the persuasion capabilities of frontier models. [18, 7, 1]

Example: A strong recent example is *ScamAgents*, which presents an autonomous multi-turn agent that generates realistic scam call scripts, maintains dialogue memory, adapts dynamically to user responses, and uses deceptive persuasion across turns. The paper shows that prompt-level safeguards can be bypassed when harmful behavior is decomposed and delivered incrementally through an agent framework. A related example is recent work on personalized social engineering in multi-turn conversations, where LLM agents simulate adversaries that build trust and attempt to extract sensitive information from victims with different personality profiles. [2, 13]

Why this is specifically about human-querying agents: This threat is specific because the querying interface is not purely epistemic. In many realistic systems, querying a human can trigger actions in the world. Once the human is part of the action loop, the security concern is no longer only what the agent knows, but also what it can get people to do.

What harm it causes: Action harm (manipulation and induced-action variants), workflow abuse, responsibility shifting, and real-world downstream consequences.

What assumptions it needs: The agent can issue requests to humans and those requests can sometimes result in action, not only information return. This does *not* require full obedience or fully autonomous execution.

9.3 Family C: Resource Exploitation

These threats exploit what the agent can consume from humans. The shared mechanism is that human attention, time, and oversight capacity are bounded resources, and structured querying can deplete or strategically misallocate them.

9.3.1 C1: Attention and Oversight Load Attacks

Short definition: Threats in which the system exploits or degrades bounded human attention, time, or oversight capacity through repeated, poorly allocated, or strategically structured querying.

Target: Human attention, human time, supervisory capacity, and the quality of oversight within the workflow.

Mechanism: The threat works by treating human input as if it were free or unlimited. The agent may over-query, repeatedly burden the same people, induce unnecessary checking or correction, or create cognitive load that degrades human performance. In this case, the harm does not require theft of a secret or a dramatic manipulation event. It is enough that the querying process itself systematically consumes scarce human capacity or weakens human oversight. This is strongly mo-

tivated by the Human API paper’s explicit treatment of sensing costs and by the broader oversight literature. [18]

Example: A direct oversight-related example comes from work on supervising computer-use agents, which shows that current oversight traces can be informative but also cumbersome, and that designing oversight that is not overwhelming remains a core challenge. A complementary behavioral example comes from *Bias in the Loop*, which finds that requiring humans to correct flagged AI errors reduced engagement and increased acceptance of incorrect suggestions. Together, these papers illustrate how burden and oversight load can themselves become a failure mode, even without direct data theft. [10, 3]

Why this is specifically about human-querying agents: This threat depends on the fact that humans are embedded as callable components in the agent’s workflow. If human queries are explicit actions, then human attention becomes an exploitable system resource rather than a vague background cost.

What harm it causes: Resource harm, degraded oversight, unfair concentration of work, institutional slowdown, and increased likelihood of downstream errors.

What assumptions it needs: Human attention is bounded, querying consumes non-zero effort, and the agent can issue multiple requests over time. This does *not* require malicious humans or full autonomy.

10. Assumptions

The threat model relies on five assumptions. Each is stated positively and is intended to be defended in the document where relevant. We additionally enumerate explicitly what is *not* assumed, since many adjacent literatures rely on stronger conditions and reviewers will look first at what is being taken for granted.

1. **Querying capability.** The agent can issue at least one structured query to at least one human through some operational interface, in the sense of the Human API framework. [18, 19]
2. **State persistence.** The agent maintains some form of state across interactions: explicit memory, accumulated observations, an implicit representation in context, or a learned model. Past human responses can influence future querying, representation, or action.
3. **Adversary access.** At least one of the following is realisable in deployment: a malicious or misaligned principal who tasks the agent; an external party who shapes the agent’s context or task; or a misaligned agent objective with respect to the queried human.
4. **Bounded human rationality.** Humans queried by the agent operate under cognitive load, time pressure, or institutional norms that make local rather than sequential evaluation of agent requests realistic. Humans need not be naive or deceived for the threat surface to apply.
5. **Non-trivial information structure.** The information the agent could acquire about a

human is correlated, in the sense that aggregation across queries can produce sensitive conclusions that no single response directly discloses. [12, 4]

We deliberately do *not* assume: an explicit symbolic graph representation of the human; weak or absent oversight; a fully autonomous agent; obedient or fully cooperative humans; access to model weights, training data, or privileged memory by the adversary; or perfectly truthful human responses. The threat surface defined here is intended to apply to current agentic systems under realistic conditions.

11. Paper-to-Project Map

11.1 Human API paper

One-sentence thesis: [...]

What object is being modelled? [...]

What is useful for my project? [...]

What language or concepts can I reuse? [...]

What does this paper not cover that my project must cover? [...]

How this changes my project framing: [...]

11.2 AI Agent Traps paper

One-sentence thesis: [...]

How is the threat taxonomy structured? [...]

What makes their taxonomy clear? [...]

Which categories feel analogous to my project? [...]

What should I copy stylistically, not substantively? [...]

How this changes my project framing: [...]

11.3 Multi-Agent Security paper

One-sentence thesis: [...]

How do they justify a new field / new threat surface? [...]

Which threat types are most relevant to my case? [...]

Which ideas help me talk about interaction-driven harm? [...]

How this changes my project framing: [...]

11.4 Privacy paper

One-sentence thesis: [...]

How do they define privacy more carefully than PII leakage? [...]

What counts as privacy harm here? [...]

Why are secrets / in-groups / context hard to define? [...]
How this strengthens my threat model: [...]

12. Per-Paper Extraction Notes

Paper title: [Title]

Citation / filename: [...]

Date read: [...]

Why Umang gave me this paper: [...]

Main contribution: [...]

What object is being secured or attacked? [...]

Who is the attacker? [...]

What assumptions are being made? [...]

What harms are recognized? [...]

Useful terms / definitions: [...]

What parts are relevant to my project? [...]

What parts are not relevant to my project? [...]

One paragraph I could reuse in my literature review: [...]

One paragraph this paper inspired for my own threat model: [...]

13. Open Questions

13.1 Conceptual Confusions

[What do I still not understand?]

13.2 Scope Questions

[What am I afraid is too broad?]

13.3 Assumption Questions

[Which assumptions feel too strong?]

13.4 Simulation Questions

[What would be the simplest later demo?]

13.5 Questions to Ask Umang / Kosta

[Write them as direct, specific questions.]

14. Candidate Toy Instantiations

Note: The setups below are candidate designs for later discussion with Umang and Kosta. They are written out at this stage to keep the threat model honest, not as commitments. Particularly the choice between A1 (representation extraction) and A2 (adaptive query inference) as the first demo should be confirmed in supervision before any code is written.

14.1 Toy Setup 1: Representation Recovery on the Human API (candidate)

Core idea: Take the existing 62-action medical sensing codebase from Oliver et al. [18]. Augment the simulated patient with a small attribute graph: a set of sensitive attributes (e.g., a stigmatised diagnosis, a substance-use history) connected to non-sensitive observable attributes via probabilistic edges. Each human endpoint (patient, nurse, specialist) is simulated as an LLM with access to ground truth. The agent maintains state across queries, instantiating the representation that is the attack target.

Attack: A principal whose objective is recovery of a specific sensitive attribute, rather than a correct diagnosis, issues legitimate sensing actions through the standard interface. Compare a random querying baseline against an adaptive, entropy-guided attacker, in the spirit of Lyu et al. [14] but applied to a human-querying rather than memory-extraction setting.

Why it is tractable: The codebase, the action registry, the cost model, and the simulated human endpoints already exist. The only new components are the attribute graph and the attacker’s policy. The graph reconstruction literature provides off-the-shelf algorithms.

What it would demonstrate: That an agent operating entirely within its legitimate query interface, against cooperative simulated humans, can recover a sensitive attribute that no individual sensing action discloses, in significantly fewer queries than a random baseline. This would validate Family A attacks (specifically A1 and A2) in a concrete, costed setting.

What assumptions it needs: Only those listed in Section 9. The attribute graph operationalises Assumption 5; the agent’s state operationalises Assumption 2.

What is unrealistic about it: Humans are LLMs with ground-truth access, while real humans are noisier, more strategic, and may refuse. The attribute graph is hand-specified rather than learned. The cost registry is fixed and not differentiated across patients.

14.2 Toy Setup 2: Human Endpoint as LLM (candidate)

Core idea: [...]

Why it is tractable: [...]

What it would demonstrate: [...]

What assumptions it needs: [...]

What is unrealistic about it: [...]

14.3 Toy Setup 3: Attention / Burden Attack (candidate)

Core idea: [...]

Why it is tractable: [...]

What it would demonstrate: [...]

What assumptions it needs: [...]

What is unrealistic about it: [...]

15. Early Paper Outline

15.1 Tentative Title

[Write 3 title options.]

15.2 Abstract Sketch

[Write 5–7 sentences only.]

15.3 Introduction Sketch

[What is the problem? Why now? What is new? What do I contribute?]

15.4 Section 1: System Model

[What will go here?]

15.5 Section 2: Threat Model

[What will go here?]

15.6 Section 3: Threat Taxonomy

[What will go here?]

15.7 Section 4: Example / Toy Instantiation

[What will go here?]

15.8 Section 5: Discussion / Assumptions / Limitations

[What will go here?]

16. Daily Log

Day / Date: [...]

What I read today: [...]

What I understood today: [...]

What is still confusing: [...]

One sentence that could go into the paper: [...]

One concrete next step for tomorrow: [...]

17. Very Short Weekly Summary

This week I clarified: [...]

This week I added: [...]

Biggest remaining confusion: [...]

Best candidate threat category so far: [...]

Best candidate toy setup so far: [...]

What I should send Umang next: [...]

18. One-Page Project Core

18.1 Problem

[1 paragraph]

18.2 System

[1 paragraph]

18.3 Attacker

[1 paragraph]

18.4 Assets

[1 paragraph]

18.5 Harm

[1 paragraph]

18.6 Why Current Literature Is Insufficient

[1 paragraph]

18.7 My Current Proposed Contribution

[1 paragraph]

References

- [1] Dario Amodei. Machines of loving grace: How AI could transform the world for the better. <https://darioamodei.com/machines-of-loving-grace>, October 2024. Essay.
- [2] Sanket Badhe. Scamagents: How AI agents can simulate human-level scam calls. *arXiv preprint arXiv:2508.06457*, 2025. doi: 10.48550/arXiv.2508.06457. URL <https://arxiv.org/abs/2508.06457>.
- [3] Jacob Beck, Stephanie Eckman, Christoph Kern, and Frauke Kreuter. Bias in the loop: How humans evaluate AI-generated suggestions. *arXiv preprint arXiv:2509.08514*, 2025. doi: 10.48550/arXiv.2509.08514. URL <https://arxiv.org/abs/2509.08514>.
- [4] Hannah Brown, Katherine Lee, Fatemehsadat Mireshghallah, Reza Shokri, and Florian Tramèr. What does it mean for a language model to preserve privacy? *arXiv preprint arXiv:2202.05520*, 2022. doi: 10.48550/arXiv.2202.05520. URL <https://arxiv.org/abs/2202.05520>.
- [5] Saswat Das, Jameson Sandler, and Ferdinando Fioretto. Beyond jailbreaking: Auditing contextual privacy in LLM agents. *arXiv preprint arXiv:2506.10171*, 2025. doi: 10.48550/arXiv.2506.10171. URL <https://arxiv.org/abs/2506.10171>.
- [6] Faouzi El Yagoubi, Ranwa Al Mallah, and Godwin Badu-Marfo. Agentleak: A full-stack benchmark for privacy leakage in multi-agent LLM systems. *arXiv preprint arXiv:2602.11510*, 2026. doi: 10.48550/arXiv.2602.11510. URL <https://arxiv.org/abs/2602.11510>.
- [7] Matija Franklin, Nenad Tomašev, Julian Jacobs, Joel Z. Leibo, and Simon Osindero. Ai agent traps. https://papers.ssrn.com/sol3/papers.cfm?abstract_id=6372438, April 2026. SSRN preprint.
- [8] David Garcia. Leaking privacy and shadow profiles in online social networks. *Science Advances*, 3(8):e1701172, 2017. doi: 10.1126/sciadv.1701172. URL <https://www.science.org/doi/10.1126/sciadv.1701172>.
- [9] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. *arXiv preprint arXiv:2302.12173*, 2023. doi: 10.48550/arXiv.2302.12173. URL <https://arxiv.org/abs/2302.12173>.

- [10] Madeleine Grunde-McLaughlin, Hussein Mozannar, Maya Murad, Jingya Chen, Saleema Amershi, and Adam Fourney. Overseeing agents without constant oversight: Challenges and opportunities. *arXiv preprint arXiv:2602.16844*, 2026. doi: 10.48550/arXiv.2602.16844. URL <https://arxiv.org/abs/2602.16844>.
- [11] Lewis Hammond et al. Multi-agent risks from advanced AI. Technical report, Cooperative AI Foundation, 2025. Cooperative AI Foundation report on multi-agent risks.
- [12] Michal Kosinski, David Stillwell, and Thore Graepel. Private traits and attributes are predictable from digital records of human behavior. *Proceedings of the National Academy of Sciences*, 110(15):5802–5805, 2013. doi: 10.1073/pnas.1218772110. URL <https://www.pnas.org/doi/10.1073/pnas.1218772110>.
- [13] Tharindu Kumarage, Cameron Johnson, Jadie Adams, Lin Ai, Matthias Kirchner, Anthony Hoogs, Joshua Garland, Julia Hirschberg, Arslan Basharat, and Huan Liu. Personalized attacks of social engineering in multi-turn conversations: LLM agents for simulation and detection. *arXiv preprint arXiv:2503.15552*, 2025. doi: 10.48550/arXiv.2503.15552. URL <https://arxiv.org/abs/2503.15552>.
- [14] Xingyu Lyu, Jianfeng He, Ning Wang, Yidan Hu, Tao Li, Danjue Chen, Shixiong Li, and Yimin Chen. Adam: A systematic data extraction attack on agent memory via adaptive querying. *arXiv preprint arXiv:2604.09747*, 2026. doi: 10.48550/arXiv.2604.09747. URL <https://arxiv.org/abs/2604.09747>.
- [15] Niloofar Miresghallah, Hyunwoo Kim, Xuhui Zhou, Yulia Tsvetkov, Maarten Sap, Reza Shokri, and Yejin Choi. Can LLMs keep a secret? testing privacy implications of language models via contextual integrity theory. In *The Twelfth International Conference on Learning Representations (ICLR)*, 2024. URL <https://openreview.net/forum?id=gmg7t8b4s0>.
- [16] Ivoline C. Ngong, Swanand Kadhe, Hao Wang, Keerthiram Murugesan, Justin D. Weisz, Amit Dhurandhar, and Karthikeyan Natesan Ramamurthy. Protecting users from themselves: Safeguarding contextual privacy in interactions with conversational agents. In *Findings of the Association for Computational Linguistics: ACL 2025*, pages 26196–26220, July 2025. URL <https://aclanthology.org/2025.findings-acl.1343/>.
- [17] Helen Nissenbaum. *Privacy in Context: Technology, Policy, and the Integrity of Social Life*. Stanford University Press, Stanford, CA, 2009.
- [18] Mary Chriselda Antony Oliver, Kostadin Devedzhiev, and Umang Bhatt. Human-mediated sensing for ai decision-making under uncertainty. April 2026. Preprint.
- [19] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can teach themselves to use tools. *arXiv preprint arXiv:2302.04761*, 2023. doi: 10.48550/arXiv.2302.04761. URL <https://arxiv.org/abs/2302.04761>.
- [20] Christian Schroeder de Witt. Open challenges in multi-agent security: Towards secure systems of interacting ai agents. *arXiv preprint arXiv:2505.02077*, 2025. doi: 10.48550/arXiv.2505.02077. URL <https://arxiv.org/abs/2505.02077>.